

Actividad: Usable Security — A Systematic Literature Review

Sección asignada: 4.4.2. Ayudar a los desarrolladores de seguridad a mejorar la usabilidad (7 artículos)

Di Nocera, F.; Tempestini, G.; Orsini, M. *Information* 2023, 14(12), 641.
<https://www.mdpi.com/2078-2489/14/12/641>

1. ¿Cuáles son las estrategias o mecanismos de seguridad usable que se presentan?

a) Incluir información de seguridad en la documentación de APIs, y sobre todo ubicarla bien [45]

- Las APIs, aunque no estén diseñadas explícitamente con fines de seguridad, suponen un riesgo si se utilizan incorrectamente.
- Gorski et al. investigaron tres cuestiones: en qué medida influye la **ubicación** de la información de seguridad dentro de la documentación, cómo leen los desarrolladores esa documentación (mediante seguimiento ocular), y el impacto de incluir instrucciones de ciberseguridad (CSP) sobre la funcionalidad y la seguridad del producto final.

b) Enfoque de desarrollo "orientado a conceptos" frente al "orientado al código" [45]

- Los desarrolladores van directo al código de ejemplo. La estrategia no es pelear contra ese hábito sino aprovecharlo: colocar las indicaciones de seguridad **junto al código funcional**, como comentarios que remitan al capítulo correspondiente.
- Aunque se probó en documentación de APIs, el principio aplica a cualquier herramienta de desarrollo donde un mal uso pueda vulnerar al usuario final o al propio código.
- Complemento: que los proveedores de bibliotecas entreguen cadenas de código CSP a la medida junto con su servicio.

c) Content Security Policy (CSP) como capa de seguridad

- Política del navegador que define qué puede y qué no puede ejecutarse (scripts, estilos, imágenes, iframes, conexiones), con el objetivo de reducir

la superficie de ataque. En el estudio funciona como el mecanismo concreto sobre el que se mide todo lo demás.

d) Patrones y modelos de GUI con la seguridad como eje de diseño [47]

- Alemerien propone modelos de seguridad para que los desarrolladores de redes sociales diseñen entornos interactivos que protejan la privacidad y la seguridad de las personas sin dejar de ser extremadamente fáciles de usar.
- La clave es la **retroalimentación adecuada**: que la interfaz ayude al usuario a tomar decisiones informadas de seguridad y privacidad.

e) Interfaces claras para identificar phishing [43]

- El mismo principio reaparece al identificar sitios web y correos fraudulentos, pero con un límite: el reconocimiento depende directamente de la capacitación previa del usuario. Una interfaz clara ayuda, pero no es determinante.
- Recomendaciones puntuales: hacer el ámbito más evidente, proporcionar una vista previa para observar los cambios y trasladar algunas operaciones directamente al navegador.

f) Diseño de correo electrónico seguro no intrusivo [44]

- Roth et al. proponen un enfoque para usuarios de correo privado no comercial: cifrado **automático y transparente**, que minimiza la interacción del usuario.
- Evita deliberadamente componentes complejos como las infraestructuras de clave pública o la "Web of Trust", y **separa el intercambio de claves de su vinculación a las identidades**, permitiendo al usuario equilibrar usabilidad y seguridad.
- Se apoya en principios de ingeniería ya establecidos: simplicidad, valores predeterminados a prueba de fallos, facilidad de uso y metáforas de interacción familiares.

g) Diseño participativo de la seguridad con las partes interesadas [42]

- Flechais y Sasse trabajan sobre e-ciencia: plataformas que dan a numerosos usuarios acceso a recursos computacionales, datos y software valiosos, donde descuidar la seguridad frustra el propósito mismo de la plataforma.
- El mecanismo es organizativo, no técnico: involucrar a las partes interesadas durante el diseño de la seguridad para identificar sus necesidades reales y, de paso, elevar su concienciación.

- Cuatro factores identificados mediante codificación con ATLAS.ti: **motivación, responsabilidad, comunicación y partes interesadas**. Asignar responsabilidades concretas aumenta notablemente la motivación de los responsables de seguridad.
- Los métodos basados en escenarios se ajustan mucho mejor a cómo las personas suelen comunicarse sobre seguridad.

h) Traducir conceptos abstractos de seguridad en criterios medibles [46]

- Dhillon et al. definen objetivos basados en valores. Tras varias fases de entrevistas y análisis estadísticos redujeron los objetivos a cuatro: maximizar la facilidad de uso, mejorar la comunicación relacionada con el sistema, maximizar la estandarización y la integración, y maximizar la capacidad del sistema.
- Estos objetivos sirven de guía para orientar la implementación y el desarrollo de software.

Transversal a todos

- La propia sección concluye que hace falta una **metodología común** que permita replicar los estudios y establecer un enfoque estandarizado sobre estos criterios.
-

2. ¿Cuáles son las características de los usuarios involucrados?

Desarrolladores

- No hay un grupo homogéneo de desarrolladores: cada uno se dedica a un área en específico (web, navegadores, sistemas, correo electrónico, ámbito académico, etc.).
- No cuentan todos con la misma experiencia, lo que influye en cómo se relacionan con la documentación de seguridad (el estudio de Gorski et al. trabajó específicamente con 49 desarrolladores noveles).
- La mayoría utiliza estrategias "orientadas al código" (buscar la solución directamente en las líneas funcionales de ejemplo) en lugar de estrategias "orientadas a los conceptos" (leer primero las partes descriptivas o explicativas de la documentación), por lo que ignoran los comentarios y descripciones y van directo al código de ejemplo.
- Tienden a descartar la seguridad cuando no encuentran indicaciones claras: sin instrucciones visibles sobre seguridad, resuelven el problema eliminando el fragmento de código conflictivo en lugar de corregirlo (uno

de los participantes incluso comentó dejar la seguridad de lado "por ahora").

- Responden mejor cuando las indicaciones de seguridad están colocadas cerca del código funcional: cuando la documentación incluía sugerencias de seguridad junto a los ejemplos que consultaban, lograban resolver el problema manteniendo el software seguro.
- Perciben la usabilidad como algo secundario o de menor importancia que la seguridad, y en ocasiones consideran innecesario consultar a especialistas en usabilidad, viéndolo como pérdida de tiempo.
- Su motivación en materia de seguridad aumenta cuando se les asignan responsabilidades específicas y se les involucra en el proceso de diseño, en lugar de dejarlo como una tarea difusa o compartida sin dueño claro.

Usuarios finales

- Muestran interés genuino en proteger su información personal, lo que se refleja en su preferencia por interfaces con más opciones relacionadas con la seguridad y privacidad.
 - Priorizan la satisfacción, la facilidad de aprendizaje y la simplicidad de uso por encima de la complejidad técnica de un sistema.
 - Tienen dificultad para detectar amenazas técnicas sutiles (como URLs incorrectas o direcciones IP falsas en sitios de phishing), pero sí logran distinguir con buena precisión entre sitios legítimos y fraudes evidentes basados en el contexto.
 - Prefieren soluciones simples, automáticas y no intrusivas, evitando componentes técnicos complejos (como sistemas de cifrado con claves públicas/privadas o redes de verificación de identidad entre usuarios) y pasos adicionales que interrumpan su tarea principal.
-

3. ¿Cuáles son los parámetros utilizados para medir la usabilidad del mecanismo o estrategia?

No existe un conjunto común de métricas: cada estudio definió las suyas, y esa dispersión es una de las críticas que el propio artículo formula.

Gorski et al. [45] — documentación de APIs

- Tasa de éxito en cuatro tareas de programación.
- Seguimiento ocular (*eye-tracking*): a qué elementos de la documentación prestan atención y durante cuánto tiempo.

- Calidad del producto final medida en dos ejes simultáneos: que el código **funcione** y que quede **protegido con CSP**.
- Diseño comparativo: tres grupos con la información de seguridad ubicada de distinta forma frente a un grupo de control con la documentación original de Google, sin información de ciberseguridad.

Alemerien [47] — interfaces gráficas en redes sociales

- Cuatro tareas: solicitud de aplicación, solicitud de amistad, compartir fotos y lista de amigos.
- Cinco factores por tarea: **satisfacción del usuario, facilidad de aprendizaje, actitudes, interactividad y privacidad**.
- Escala Likert de 1 a 5, comparando los modelos propuestos contra la interfaz real de Facebook.

Alsharnouby et al. [43] — phishing

- Porcentaje de aciertos al identificar sitios fraudulentos, desglosado por **tipo de amenaza** (siete tipos).
- Movimientos oculares: tiempo dedicado a observar cada aspecto de la pantalla.
- Razonamiento verbalizado detrás de la toma de decisiones.

Roth et al. [44] — correo seguro

- Sin métricas cuantitativas: entrevistas a 19 usuarios.
- La evaluación se hace contra **principios de diseño**: simplicidad, valores predeterminados a prueba de fallos, mínima interacción del usuario, metáforas de interacción familiares y la noción de "seguridad por interacción".

Flechais y Sasse [42] — e-ciencia

- Enfoque puramente cualitativo: transcripciones de cuatro estudios de caso codificadas con la herramienta **ATLAS.ti**.
- Categorías de codificación: motivación, responsabilidad, comunicación y partes interesadas.

Dhillon et al. [46]

- Entrevistas y análisis estadístico para reducir objetivos abstractos a cuatro criterios medibles: facilidad de uso y comunicación del sistema, estandarización e integración, y capacidad del sistema.
-

4. ¿Cuáles fueron los resultados en cada caso?

Gorski et al. [45]

- Los desarrolladores siguen estrategias orientadas al código: buscan de inmediato la solución en las líneas funcionales del ejemplo, ignorando las partes descriptivas.
- Grupo de control (sin instrucciones de CSP): todos entregaron código que **funcionaba pero ninguno estaba protegido**. Resolvieron el conflicto eliminando directamente el fragmento problemático. Un participante llegó a comentar que dejaba la seguridad de lado "por ahora".
- Grupos con sugerencias de CSP **en forma de comentarios dentro del código de ejemplo**: la mayoría entregó software operativo y a la vez seguro.
- Conclusión: la ubicación de la indicación importa más que su mera existencia. Se añade la sugerencia de que los proveedores de bibliotecas entreguen cadenas de CSP personalizadas junto con su servicio.

Alemerien [47]

- Los usuarios muestran un gran interés en proteger su información personal.
- En las cuatro tareas prefirieron las interfaces propuestas sobre las de Facebook, que resultaron más complejas y con menos opciones relacionadas con la seguridad.
- Los modelos propuestos ofrecen retroalimentación adecuada e interfaces eficaces que ayudan a decidir en materia de seguridad y privacidad, logrando un mejor equilibrio entre usabilidad y seguridad.

Alsharnouby et al. [43]

- Sitio bancario falsificado con URL incorrecta: en general los participantes no reconocieron la URL incorrecta. En cambio, sí identificaron correctamente el sitio del Gobierno canadiense.
- Solo el **38 %** notó que el sitio de PayPal tenía una dirección IP en lugar de una URL.
- Chrome falso: el **62 %** lo reconoció como intento de phishing.
- Ventanas emergentes que solicitaban credenciales: el **38 %** **cayó** en la trampa.
- Ventanas emergentes superpuestas: el **62 %** lo reconoció, a pesar de que se veía una doble URL.

- Fraude basado en el contexto ("Credit Card Checker"): el 95 % lo reconoció, probablemente por concienciación mediática.
- Sitios web legítimos: altas tasas de acierto.
- Lectura general: los usuarios distinguen bien lo "normal" de lo "sospechoso" por contexto, pero son prácticamente ciegos a los indicadores técnicos. La interfaz ayuda; la capacitación es la que decide.

Roth et al. [44]

- Propuesta de correo seguro no intrusivo, con cifrado automático y transparente que minimiza la interacción del usuario.
- Cuestionan que los usuarios privados y no comerciales necesiten infraestructuras de certificación.
- Dejan tres líneas de investigación abiertas: mejorar la interacción persona-ordenador para una verificación de claves fácil de usar, desarrollar mejores métricas para maximizar la seguridad por interacción, y encontrar formas de incentivar los esfuerzos de seguridad desde la propia interfaz.

Flechais y Sasse [42]

- Involucrar a las partes interesadas en el diseño de la seguridad es un medio muy eficaz para identificar sus necesidades y, además, aumenta su concienciación sobre las cuestiones de seguridad del sistema.
- La asignación de responsabilidades incrementa notablemente la motivación de los responsables de seguridad.
- El proceso de diseño debe ser participativo, inclusivo y comprensible para todos los participantes, con buena comunicación entre ellos.
- Los métodos de seguridad basados en escenarios se ajustan mucho mejor a la forma en que las personas se comunican sobre seguridad.

Dhillon et al. [46]

- Cuatro objetivos finales útiles para orientar la implementación y el desarrollo de software: maximizar la facilidad de uso, mejorar la comunicación relacionada con el sistema, maximizar la estandarización y la integración, y maximizar la capacidad del sistema.
-

5. ¿Qué áreas de oportunidad se detectan?

- **Falta de una metodología común.** Es el problema central que señala la propia sección: sin una metodología compartida no se pueden replicar los estudios ni establecer un enfoque estandarizado para abordar la cuestión.

- **Recomendaciones generales sin respaldo empírico real.** Aunque el objetivo declarado es orientar a los desarrolladores durante la fase de diseño, muchas conclusiones no parecen basarse en un trabajo empírico genuino. Varias se asemejan a reflexiones "organizativas": asignar responsabilidades, comprender motivaciones, hacer el proceso participativo, identificar escenarios.
- **Se confunde "facilidad de uso" con "usabilidad".** Se insta a los desarrolladores a simplificar el diseño o a integrar la GUI con los aspectos de seguridad, pero nunca se define qué significa eso en concreto. Los desarrolladores necesitarían información más detallada y accionable.
- **Ni las recomendaciones más específicas se salvan.** Las de Alsharnouby et al. (hacer el ámbito más evidente, dar vista previa de los cambios, trasladar operaciones al navegador) tampoco derivan de un trabajo empírico sistemático.
- **El hallazgo de Gorski et al. está subaprovechado.** Se probó únicamente en documentación de APIs, pero el principio de colocar la indicación de seguridad donde el desarrollador realmente va a mirar aplica a cualquier herramienta de desarrollo.
- **La capacitación del usuario queda fuera del alcance del diseño.** Los resultados sobre phishing dejan claro que una interfaz clara no compensa la falta de formación previa, y ningún estudio del grupo aborda esa dimensión.
- **Ausencia de requisitos de seguridad usable en los contextos de desarrollo** (crítica general de la revisión), lo que desincentiva la aplicación de buenas prácticas desde las etapas tempranas.
- **Falta de métricas estandarizadas de "seguridad por interacción",** señalada explícitamente por Roth et al. como línea pendiente.
- **Necesidad general de mayor rigor metodológico y mayor especificidad** en las recomendaciones que se entregan a los desarrolladores.